

Security+ 2.4 · Denial of Service

Mestre CyberSec · Aula 2.4 — Denial of Service (6:07) · [Assistir Vídeo no YouTube](#) · Treino Interativo: edusouzamarques.github.io/cybersec

Resumo Executivo da Aula: DoS (uma origem) derruba serviço; DDoS (distribuído — botnet de milhares de máquinas). Técnicas: amplification (requisição GRANDE pra servidor aberto que amplifica); SYN flood (meio handshake TCP deixa conexões penduradas); ICMP/ping flood. Defesa: CDN (Cloudflare/Akamai na frente)

💡 Highlights que a prova CompTIA cobra

- DoS/DoS: uma origem; DDoS: botnet de milhares — amplifica
- Amplification attack: req de 50 bytes gera resposta de 4000 (DNS/NTP abertos)
- Defesa principal: CDN / CloudFlare — absorve na borda antes de chegar

🎯 Dicas de Prova & Cenários Típicos da Banca

- 'thousands of machines send traffic simultaneously' = DDoS
- 'uses DNS or NTP servers to amplify traffic' = amplification attack

Por que este aprofundamento é cobrado na prova?: O vídeo resume os tópicos práticos, mas o exame CompTIA SY0-701 cobra discernimento técnico rigoroso sobre as tecnologias e protocolos específicos desta seção:

• Negação de Serviço (DoS)

Ataque originado de uma única fonte que inunda um serviço com tráfego ou explora uma falha para torná-lo indisponível a usuários legítimos.

 **Armadilha CompTIA:** Se o enunciado diz 'single source', 'one machine' ou 'uma única origem', a resposta é DoS — nunca DDoS.

• Negação de Serviço Distribuída (DDoS)

Ataque DoS coordenado, originado de milhares de hosts comprometidos simultaneamente, tornando muito difícil o bloqueio por um único IP de origem.

 **Armadilha CompTIA:** Gatilho clássico: 'thousands of machines send traffic simultaneously' = DDoS (e normalmente envolve botnet).

• Botnet (Rede de Bots/Zumbis)

Rede de dispositivos comprometidos (bots ou zumbis) controlados remotamente por um servidor de comando e controle (C2) e usados para lançar DDoS, spam ou mineração de criptomoedas.

 **Armadilha CompTIA:** Botnet é a FONTE do DDoS; os dispositivos infectados pertencem a terceiros, por isso bloquear por IP quase nunca funciona.

• Ataque de Amplificação (Reflexão) (Amplification)

Ataque que envia uma requisição pequena com IP falsificado a um servidor aberto de terceiros (DNS, NTP, broadcast ICMP), cuja resposta muito maior é enviada à vítima.

 **Armadilha CompTIA:** 'Pequena requisição gera resposta enorme' ou 'uses DNS or NTP servers to amplify traffic' = amplification/reflection attack (ex.: 50 bytes → 4000 bytes).

• Inundação SYN (SYN Flood)

Ataque DoS via TCP que envia muitos pacotes SYN com endereços de origem falsificados, enchendo a fila de conexões com sessões semiabertas até que clientes reais não consigam conectar.

 **Armadilha CompTIA:** 'Half-open TCP handshake deixando conexões penduradas' = SYN flood; defesa-chave: SYN cookies / firewalls stateful.

• Inundação ICMP (Ping Flood) (ICMP Flood)

Ataque de volume que sobrecarrega o alvo com pacotes ICMP Echo Request, consumindo largura de banda e recursos de processamento até degradar o serviço.

 **Armadilha CompTIA:** ICMP/ping flood é ataque VOLUME-based (banda); distinga do SYN flood, que é de PROTOCOLO/estado (esgota a tabela de conexões).

• Rede de Distribuição de Conteúdo (CDN)

Conjunto distribuído geograficamente de servidores de borda que armazenam conteúdo em cache e absorvem/filtram tráfego malicioso na borda antes de chegar ao servidor de origem.

 **Armadilha CompTIA:** Defesa principal de DDoS citada pelo Messer: CDN (Cloudflare/Akamai) absorve na borda — a origem nunca vê o volume total do ataque.

• Limitação de Taxa (Rate Limiting)

Controle de mitigação que limita o número de requisições aceitas de uma origem ou por sessão, reduzindo o impacto de ataques de inundação e força bruta.

 **Armadilha CompTIA:** Complemento da CDN/WAF na defesa contra DoS: se a questão fala em 'limitar requisições por origem', pense em rate limiting, não em criptografia.

✓ Perguntas de Treino Comentadas (10 Questões de Cenários Reais)

Cenários autênticos alinhados aos objetivos do exame. O gabarito com análise completa dos distratores encontra-se ao final.

QUESTÃO 1 · CENÁRIO DE EXAME

O site de um varejista online fica inacessível durante um período de pico de vendas. O NOC relata tráfego de entrada de milhares de endereços IP públicos únicos em vários países, todos solicitando as mesmas páginas de produtos. Nenhum IP de origem único domina o tráfego. Qual tipo de ataque provavelmente está ocorrendo?

- A) Um ataque de amplificação DNS refletido
- B) Um ataque de negação de serviço distribuído (DDoS)
- C) Uma inundação SYN TCP
- D) Uma inundação de eco ICMP

QUESTÃO 2 · CENÁRIO DE EXAME

Um analista de segurança observa que o servidor DNS público de uma organização está recebendo muitas consultas pequenas com endereços IP de origem falsificados definidos como o IP da vítima. O servidor envia respostas DNS grandes para a vítima, saturando o link de internet dela. Qual técnica está sendo usada?

- A) Inundação SYN TCP
- B) Inundação de ping ICMP
- C) Ataque de reflexão/amplificação DNS
- D) Ataque HTTP slow POST

QUESTÃO 3 · CENÁRIO DE EXAME

A tabela de conexões de um servidor web está cheia de conexões TCP semiabertas. Os clientes enviam pacotes SYN, mas nunca completam o handshake de três vias, impedindo que usuários legítimos se conectem. Qual ataque é descrito?

- A) Ataque de inundação SYN
- B) Ataque de amplificação DNS
- C) Ataque de inundação ICMP
- D) Ataque Slowloris

QUESTÃO 4 · CENÁRIO DE EXAME

Um roteador de filial apresenta alto uso de CPU. O monitoramento de rede mostra um grande volume de solicitações de eco ICMP chegando de vários hosts da internet, e o roteador responde a cada solicitação. Qual ataque é mais provável?

- A) Inundação SYN
- B) Amplificação DNS
- C) Inundação ICMP
- D) Inundação HTTP

QUESTÃO 5 · CENÁRIO DE EXAME

Os servidores de uma empresa de jogos são inundados com tráfego de ataque originado de milhares de roteadores domésticos e câmeras IP comprometidos. Os dispositivos recebem comandos de um servidor de comando e controle externo. Qual termo descreve melhor a coleção de dispositivos comprometidos?

- A) Botnet
- B) Rede de distribuição de conteúdo
- C) Rede privada virtual
- D) Balanceador de carga

QUESTÃO 6 · CENÁRIO DE EXAME

Uma empresa quer reduzir o impacto de um grande ataque DDoS volumétrico contra seu site público sem mover a aplicação para um novo data center. Qual mitigação é mais apropriada?

- A) Implantar uma rede de distribuição de conteúdo com depuração de DDoS e cache de borda.
- B) Instalar RAM adicional nos servidores web.
- C) Ativar criptografia de disco completo nos servidores de banco de dados.
- D) Rotacionar chaves SSH no balanceador de carga.

QUESTÃO 7 · CENÁRIO DE EXAME

Um gateway de API está sendo abusado por um único cliente autenticado que envia milhares de requisições por segundo, fazendo com que usuários legítimos recebam erros. A equipe de segurança quer limitar o número de requisições permitidas desse cliente, preservando o acesso normal para os demais. Qual controle deve ser implementado?

- A) DNSSEC na zona DNS pública
- B) Limitação de taxa no gateway de API
- C) Criptografia de disco completo nos servidores de API
- D) 802.1X em pontos de acesso sem fio

QUESTÃO 8 · CENÁRIO DE EXAME

Uma organização descobre que um serviço UDP exposto à internet está sendo usado em um ataque de amplificação. Atacantes enviam requisições falsificadas ao serviço, e o serviço retorna respostas grandes para vítimas. Qual mitigação reduz melhor esse risco específico?

- A) Desativar serviços UDP desnecessários e aplicar filtragem de ingresso anti-spoofing.
- B) Ativar TLS 1.3 para todos os serviços UDP.
- C) Implantar antivírus baseado em host nos laptops dos funcionários.
- D) Aumentar a complexidade de senhas para contas de serviço.

QUESTÃO 9 · CENÁRIO DE EXAME

Durante um ataque DDoS, os servidores web de uma empresa mostram uso normal de CPU e memória, mas a conexão de internet está completamente saturada. Qual mitigação é mais apropriada para esse tipo de ataque?

- A) Instalar RAM adicional nos servidores web.
- B) Usar uma CDN com depuração de DDoS e filtragem de tráfego.
- C) Ativar indexação de banco de dados para o catálogo de produtos.
- D) Rotacionar chaves SSH no balanceador de carga.

QUESTÃO 10 · CENÁRIO DE EXAME

Um serviço online está sofrendo uma inundação HTTP na camada de aplicação originada de uma botnet. As requisições parecem visualizações de página normais, mas chegam a uma taxa muito alta e esgotam os recursos do servidor. Qual estratégia de mitigação é mais apropriada?

- A) Implantar um firewall de aplicação web com limitação de taxa e colocar o site atrás de uma CDN.
- B) Estender a retenção de captura de pacotes para 90 dias.
- C) Atribuir endereços IP estáticos a todos os clientes internos.
- D) Ativar DNSSEC nos servidores DNS internos.

GABARITO COMENTADO COM ANÁLISE DE DISTRATORES

Questão 1: Alternativa B — Um ataque de negação de serviço distribuído (DDoS)

O indicador principal é um ataque de alto volume proveniente de muitas fontes distintas, característico de um ataque DDoS. Um ataque de amplificação DNS mostraria respostas DNS grandes, uma inundação SYN mostraria conexões TCP semiabertas e uma inundação de eco ICMP seria principalmente tráfego ICMP. Ataques DDoS frequentemente usam uma botnet de hosts comprometidos para sobrecarregar o alvo.

Questão 2: Alternativa C — Ataque de reflexão/amplificação DNS

Em um ataque de reflexão/amplificação DNS, o atacante envia consultas pequenas falsificadas para resolvedores DNS abertos. Os resolvedores enviam respostas maiores para o IP falsificado da vítima, amplificando o tráfego. Uma inundação SYN ataca o estado da conexão TCP, uma inundação ICMP usa solicitações de eco e um ataque slow POST ataca recursos da camada de aplicação.

Questão 3: Alternativa A — Ataque de inundação SYN

Uma inundação SYN explora o handshake de três vias do TCP enviando muitos pacotes SYN com endereços de origem falsificados ou incompletos. O servidor aloca recursos para conexões semiabertas até esgotar sua tabela de conexões. O Slowloris também mantém conexões abertas, mas normalmente completa o handshake TCP e envia requisições HTTP parciais.

Questão 4: Alternativa C — Inundação ICMP

Uma inundação ICMP, também chamada de inundação de ping, sobrecarrega um alvo com solicitações de eco ICMP. Quando o alvo responde a cada solicitação, sua CPU e largura de banda podem ser esgotadas. Inundações SYN atacam o estado TCP, a amplificação DNS usa consultas DNS falsificadas e inundações HTTP atacam aplicações web.

Questão 5: Alternativa A — Botnet

Uma botnet é uma rede de dispositivos comprometidos, frequentemente chamados de bots ou zumbis, controlada por um servidor de comando e controle. Atacantes usam botnets para lançar ataques DDoS em larga escala. Uma CDN distribui conteúdo, uma VPN fornece acesso remoto criptografado e um balanceador de carga distribui tráfego para servidores.

Questão 6: Alternativa A — Implantar uma rede de distribuição de conteúdo com depuração de DDoS e cache de borda.

Uma CDN com depuração de DDoS e cache de borda pode absorver e distribuir o tráfego volumétrico de ataque entre muitas localidades de borda, protegendo os servidores de origem. Adicionar RAM não resolve o esgotamento de largura de banda da rede. A criptografia de disco completo protege dados em repouso, e a rotação de chaves SSH melhora a segurança de acesso, mas não mitiga DDoS volumétrico.

Questão 7: Alternativa B — Limitação de taxa no gateway de API

A limitação de taxa restringe quantas requisições um cliente pode fazer dentro de uma janela de tempo específica, ajudando a prevenir abusos e DoS na camada de aplicação. DNSSEC protege a integridade do DNS, criptografia de disco completo protege dados em repouso e 802.1X controla acesso à rede, mas não limita o volume de requisições de API.

Questão 8: Alternativa A — Desativar serviços UDP desnecessários e aplicar filtragem de ingresso anti-spoofing.

Ataques de amplificação abusam de serviços UDP abertos que retornam respostas grandes para IPs de origem falsificados. Desativar serviços UDP desnecessários reduz a superfície de ataque, e a filtragem de ingresso ajuda a impedir que pacotes falsificados saiam das redes. TLS 1.3 é para criptografia baseada em TCP, antivírus não impede amplificação de rede e complexidade de senha não resolve tráfego UDP falsificado.

Questão 9: Alternativa B — Usar uma CDN com depuração de DDoS e filtragem de tráfego.

Se a CPU e a memória estão normais, mas o link de internet está saturado, o ataque é volumétrico e tem como alvo a largura de banda da rede. Uma CDN com depuração de DDoS pode filtrar e distribuir tráfego malicioso antes que ele alcance a origem. Adicionar RAM, indexar um banco de dados ou rotacionar chaves SSH não resolve a saturação de largura de banda.

Questão 10: Alternativa A — Implantar um firewall de aplicação web com limitação de taxa e colocar o site atrás de uma CDN.

Uma inundação HTTP ataca a camada de aplicação com muitas requisições aparentemente legítimas. Um WAF pode inspecionar e filtrar tráfego HTTP malicioso, a limitação de taxa pode controlar o volume de requisições e uma CDN pode absorver tráfego distribuído. A retenção de captura de pacotes ajuda na perícia, mas não impede o ataque; IPs estáticos não mitigam botnets externas; e DNSSEC protege a integridade do DNS.